

INTRODUCTION AU TEST D'INTRUSION

Guide de méthode

Projet final · Conduire une mission sur dossier

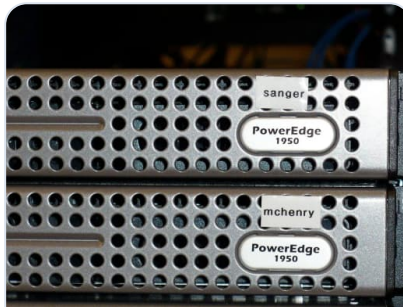


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



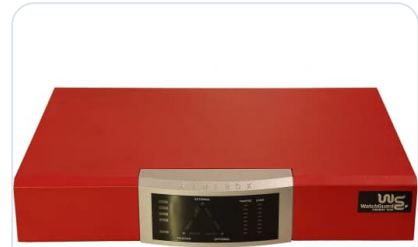
Ordinateur portable

L'ordinateur que l'on emporte partout



Serveur

Fournit fichiers, messagerie ou site web aux autres



Pare-feu (firewall)

Filtre le trafic entre deux zones selon des règles

Photos issues de Wikimedia Commons : Ordinateur portable, Ahunt, CC0 · Serveur, Florence Devouard, CC BY-SA 4.0 · Pare-feu (firewall), Jakez, CC BY-SA 3.0.

À RETENIR

- ◆ Cadre et limites : tu analyses uniquement des fichiers fournis. Ne teste jamais un système réel sans autorisation écrite. Les exemples ci-dessous utilisent des valeurs inventées, pas celles du dossier.

1 Commencer par le cadrage

Lis d'abord la synthèse de cadrage pour relever le périmètre, la fenêtre horaire, les exclusions et la liste des services attendus. Une réponse n'est valable que si elle respecte ces bornes.

2 Croiser des ensembles OSINT

Quand une question oppose présence dans les sources passives et absence dans le DNS actif, isole les lignes par colonnes, puis compare les ensembles. Une technologie se compte une seule fois par source distincte.

BASH

```
cat > osint-exemple.csv <<'EOF'
ligne;fqdn;source;dns_statut;technologie
001;demo.example;ct_log;absent;apache
002;demo.example;archive_page;absent;apache
003;portail.demo.example;dns_zone;actif;caddy
004;portail.demo.example;capture_entete;actif;caddy
EOF
grep ';absent;' osint-exemple.csv | cut -d';' -f2 | sort | uniq
```

POWERSHELL

```
@'
ligne;fqdn;source;dns_statut;technologie
001;demo.example;ct_log;absent;apache
002;demo.example;archive_page;absent;apache
003;portail.demo.example;dns_zone;actif;caddy
004;portail.demo.example;capture_entete;actif;caddy
'@ | Set-Content -Encoding UTF8 osint-exemple.csv
Import-Csv -Delimiter ';' -Encoding UTF8 osint-exemple.csv | Where-Object { $_.dns_statut -eq 'absent' } | Group-Object
fqdn | Select-Object Name, Count
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

3 Lire un XML Nmap

Dans ce parcours, un hôte ne compte que si son état est `up`. Pour repérer un couple inattendu, il faut lister les ports `open`, puis comparer au tableau des services attendus du cadrage. En XML Nmap, un service HTTPS peut apparaître comme `name="http" tunnel="ssl"` plutôt que comme une chaîne unique.

BASH

```
cat > nmap-exemple.xml <<'EOF'
<nmaprun>
  <host><status state="up"/><address addr="198.51.100.10"/><hostnames><hostname name="demo.example"/></hostnames><ports>
<port protocol="tcp" portid="443"><state state="open"/></port></ports></host>
  <host><status state="down"/><address addr="198.51.100.11"/><hostnames><hostname name="old.demo.example"/></hostnames>
<ports><port protocol="tcp" portid="443"><state state="closed"/></port></ports></host>
</nmaprun>
EOF
grep '<status state="up"' nmap-exemple.xml | wc -l
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

POWERSHELL

```
@'
<nmaprun>
  <host><status state="up"/><address addr="198.51.100.10"/><hostnames><hostname name="demo.example"/></hostnames>
<ports><port protocol="tcp" portid="443"><state state="open"/></port></ports></host>
  <host><status state="down"/><address addr="198.51.100.11"/><hostnames><hostname name="old.demo.example"/>
</hostnames><ports><port protocol="tcp" portid="443"><state state="closed"/></port></ports></host>
</nmaprun>
'@ | Set-Content -Encoding UTF8 nmap-exemple.xml
(Get-Content -Encoding UTF8 nmap-exemple.xml) -match '<status state="up"' | Measure-Object | Select-Object -
ExpandProperty Count
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

4 Recalculer une note CVSS puis une priorité

Recopie le vecteur, calcule la note CVSS avec la formule de la grille, puis applique les facteurs de surface, criticité, preuve, KEV et EPSS. Garde chaque étape, sinon tu ne pourras pas justifier la priorité dans le rapport.

BASH

```
cat > priorite-exemple.csv <<'EOF'
id;note;surface;criticite;preuve;kev;epss
X01;4.6;vpn;elevee;partielle;non;0.34
X02;6.1;internet;critique;suffisante;oui;0.82
EOF
awk -F';' 'NR>1 { print $1, $2, $3, $4, $5, $6, $7 }' priorite-exemple.csv
```

POWERSHELL

```
@'
id;note;surface;criticite;preuve;kev;epss
X01;4.6;vpn;elevee;partielle;non;0.34
X02;6.1;internet;critique;suffisante;oui;0.82
'@ | Set-Content -Encoding UTF8 priorite-exemple.csv
Import-Csv -Delimiter ';' -Encoding UTF8 priorite-exemple.csv | Select-Object id, note, surface, criticite, preuve, kev,
epss
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

5 Rédiger sans surinterpréter

Dans un résumé exécutif, écris ce qui est démontré, ce qui reste une hypothèse et l'action vérifiable qui réduit le risque. Une phrase prudente vaut mieux qu'une formule spectaculaire impossible à justifier.

6 Statuts et rattachements

- ◆ **constat** = preuve suffisante et corroborée;
- ◆ **hypothese** = signal plausible, mais encore incomplet;
- ◆ **faux_positif** = alerte infirmée par une pièce plus fiable;
- ◆ un contrôle d'accès cassé ou une SSRF pilotée depuis l'application se rattachent à la catégorie d'accès non autorisé décrite dans la grille.

7 Variante visionneuse

Dans la visionneuse du site, commence par le document de cadrage ou de grille, puis utilise la recherche pour un identifiant, une colonne, un code OWASP, une heure UTC ou un état **open**. Note toujours le fichier source avant de répondre.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).